

ISO/IEC 27001:2022

INTRODUCTION

ISO 27001 is the central foundation relating to Information Security Management Systems (ISMS).

An ISMS is the framework of policies and procedures that include all legal, physical, and technical controls involved in an organization's information risk management processes.

ISO 27001 controls take an adequate and appropriate risk-based approach in providing ISMS implementation requirements, enabling organizations of any size to comfortably manage security assets.

REQUIREMENTS

4. CONTEXT OF THE ORGANIZATION

4.1 Understanding the organization and its context: The organization shall determine external and internal issues that are relevant to its purpose and that affect its ability to achieve the intended outcome(s) of its information security management system.

4.2 Understanding the needs and expectations of interested parties.

4.3 Determining the scope of the Information Security Management System (Internal and External)

4.4 Information Security Management System: The organization shall establish, implement, maintain and continually improve an information security management system, including the processes needed and their interactions, in accordance with the requirements of this document.

5. LEADERSHIP

5.1 **Leadership and Commitment:**

- a) ensuring the information security policy and the information security objectives are established and are compatible with the strategic direction of the organization;
- b) ensuring the integration of the information security management system requirements into the organization's processes;
- c) ensuring that the resources needed for the information security management system are available;
- d) communicating the importance of effective information security management and of conforming to the information security management system requirements;
- e) ensuring that the information security management system achieves its intended outcome(s);
- f) directing and supporting persons to contribute to the effectiveness of the information security management system;
- g) promoting continual improvement; and
- h) supporting other relevant management roles to demonstrate their leadership as it applies to their areas of responsibility.

CONT'D

5.2 Policy: Top management shall establish an information security policy that is appropriate to the purpose of the organization;

5.3 Organizational roles, responsibilities and authorities : Top management shall ensure that the responsibilities and authorities for roles relevant to information security are assigned and communicated within the organization. Top management shall assign the responsibility and authority for:

- a) ensuring that the information security management system conforms to the requirements of this document;
- b) reporting on the performance of the information security management system to top management.

6. PLANNING

6.1 Actions to address risks and opportunities: The organization shall plan, actions to address the risks and opportunities and also should know how to integrate and implement the actions into its information security management system processes and evaluate the effectiveness of these actions.

- 6.1.2 Information security risk assessment: Basic risk assessment involves only three factors: the importance of the assets at risk, how critical the threat is, and how vulnerable the system is to that threat. Using those factors, you can assess the risk the likelihood of money loss by your organization. The organization shall define and apply an information security risk assessment process.
- 6.1.3 Information security risk treatment:
 - a) select appropriate information security risk treatment options, taking account of the risk assessment results;
 - b) determine all controls that are necessary to implement the information security risk treatment option(s) chosen;

CONT'D

- c) compare the controls determined, and verify that no necessary controls have been omitted;
- d) produce a **Statement of Applicability** that contains:
 - the necessary controls
 - justification for their inclusion;
 - whether the necessary controls are implemented or not; and
 - the justification for excluding any of the Annex A controls.
- e) formulate an information security risk treatment plan; and
- f) obtain risk owners' approval of the information security risk treatment plan and acceptance of the residual information security risks.

6.2 Information security objectives and planning to achieve them

6.3 Planning of changes: When the organization determines the need for changes to the information security management system, the changes shall be carried out in a planned manner.

7. SUPPORT

7.1 Resources - The organization shall determine and provide the resources needed for the establishment, implementation, maintenance and continual improvement of the information security management system.

7.2 Competence - The Organization has to determine the competence of the human resource that work on the ISMS , and could affect its performance. Employees should be competent on the basis of the relevant education, training or experience and the organization should take action where needed.

7.3 Awareness - This requirement is seeking confirmation that the persons doing the work are aware of the information security policy , their contribution to the effectiveness of the ISMS including benefits from its improved performance and what happens when the information security management system does not conform to its requirements.

CONT'D

7.4 Communication - The organization shall determine the need for internal and external communications relevant to the information security management system including, on what to communicate; when to communicate; with whom to communicate; how to communicate.

7.5 Documented information- The organization's information security management system shall include, documented information required by the compliance. The extent of documented information for an information security management system can differ from one organization to another due to:

- the size of organization and its type of activities, processes, products and services;
- the complexity of processes and their interactions; and
- the competence of persons.

8. OPERATION

8.1 Operational planning and control - The organization shall plan, implement and control the processes needed to meet requirements, and to implement the actions determined. Documented information shall be available to the extent necessary. The organization shall control planned changes and review the consequences of unintended changes, and shall ensure that externally provided processes, products or services are controlled.

8.2 Information security risk assessment - The organization shall perform information security risk assessments at planned intervals or when significant changes are proposed or occur, taking account of the criteria established.

8.3 Information security risk treatment - The organization shall implement the information security risk treatment plan.

9. PERFORMANCE EVALUATION

9.1 Monitoring, measurement, analysis and evaluation - The organization shall evaluate the information security performance and the effectiveness of the information security management system.

9.2 Internal audit - The organization shall conduct internal audits at planned intervals to provide information on whether the information security management system:

- a) conforms to : 1) the organization's own requirements for its information security management system; 2) the requirements of this document;
- b) is effectively implemented and maintained.

9.3 Management review - Top management shall review the organization's information security management system at planned intervals to ensure its continuing suitability, adequacy and effectiveness.

10. IMPROVEMENT

10.1 Continual improvement - The organization shall continually improve the suitability, adequacy and effectiveness of the information security management system.

10.2 Nonconformity and corrective action - When a nonconformity occurs, the organization shall:

- a) react to the nonconformity,
- b) evaluate the need for action to eliminate the causes of nonconformity, in order that it does not recur or occur elsewhere,
- c) implement any action needed;
- d) review the effectiveness of any corrective action taken; and
- e) make changes to the information security management system, if necessary.
- f) the nature of the nonconformities and any subsequent actions taken,
- g) the results of any corrective action.

ANNEX A

INFORMATION SECURITY CONTROLS REFERENCE

Annex A in ISO 27001 is a part of the standard that lists a set of classified security controls) that organizations use to demonstrate compliance with ISO 27001 . ISO 27001:2022 lists 93 controls rather than ISO 27001:2013's 114. These controls are grouped into 4 'themes'. They are:

- Organization controls (chapter 5)
- People controls (chapter 6)
- Physical controls (chapter 7)
- Technological controls (chapter 8)

Annex A controls have been both **reduced** and **restructured** to reflect the updated ISO/IEC 27001:2022

ORGANIZATIONAL CONTROLS

➤ There are 37 controls in total under organizational controls. Some of them are (fig.):

5	Organizational controls	
5.1	Policies for information security	Control Information security policy and topic-specific policies shall be defined, approved by management, published, communicated to and acknowledged by relevant personnel and relevant interested parties, and reviewed at planned intervals and if significant changes occur.
5.2	Information security roles and responsibilities	Control Information security roles and responsibilities shall be defined and allocated according to the organization needs.
5.3	Segregation of duties	Control Conflicting duties and conflicting areas of responsibility shall be segregated.
5.4	Management responsibilities	Control Management shall require all personnel to apply information security in accordance with the established information security policy, topic-specific policies and procedures of the organization.

PEOPLE CONTROLS

- These cover the controls required for secure human resources management. There are 8 controls in total some of them are (fig.) :

6	People controls	
6.1	Screening	Control Background verification checks on all candidates to become personnel shall be carried out prior to joining the organization and on an ongoing basis taking into consideration applicable laws, regulations and ethics and be proportional to the business requirements, the classification of the information to be accessed and the perceived risks.
6.2	Terms and conditions of employment	Control The employment contractual agreements shall state the personnel's and the organization's responsibilities for information security.
6.3	Information security awareness, education and training	Control Personnel of the organization and relevant interested parties shall receive appropriate information security awareness, education and training and regular updates of the organization's information security policy, topic-specific policies and procedures, as relevant for their job function.
6.4	Disciplinary process	Control A disciplinary process shall be formalized and communicated to take actions against personnel and other relevant interested parties who have committed an information security policy violation.

PHYSICAL CONTROLS

- There are 14 controls under this category, some of them are (fig.):

7	Physical controls	
7.1	Physical security perimeters	Control Security perimeters shall be defined and used to protect areas that contain information and other associated assets.
7.2	Physical entry	Control Secure areas shall be protected by appropriate entry controls and access points.
7.3	Securing offices, rooms and facilities	Control Physical security for offices, rooms and facilities shall be designed and implemented.
7.4	Physical security monitoring	Control Premises shall be continuously monitored for unauthorized physical access.

TECHNOLOGICAL CONTROLS

- There are 34 controls under this category , some of them are (fig):

8	Technological controls	
8.1	User end point devices	Control Information stored on, processed by or accessible via user end point devices shall be protected.
8.2	Privileged access rights	Control The allocation and use of privileged access rights shall be restricted and managed.
8.3	Information access restriction	Control Access to information and other associated assets shall be restricted in accordance with the established topic-specific policy on access control.
8.4	Access to source code	Control Read and write access to source code, development tools and software libraries shall be appropriately managed.

COMPARISON BETWEEN 2013 & 2022

Comparison

Old 2013 revision
Published September 25, 2013

New 2022 revision
Published October 25, 2022

11	Number of clauses in the main part of the standard	11
114	Number of security controls in Annex A	93
14	Number of sections in Annex A	4

Changes in the management system

New requirements in the main part of the standard:



4.2 c)

Requirements of interested parties to be addressed through the ISMS



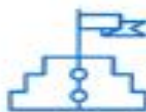
6.3

Planning of changes



8.1

Establishing criteria for processes and implementing control for them



9.3.2 c)

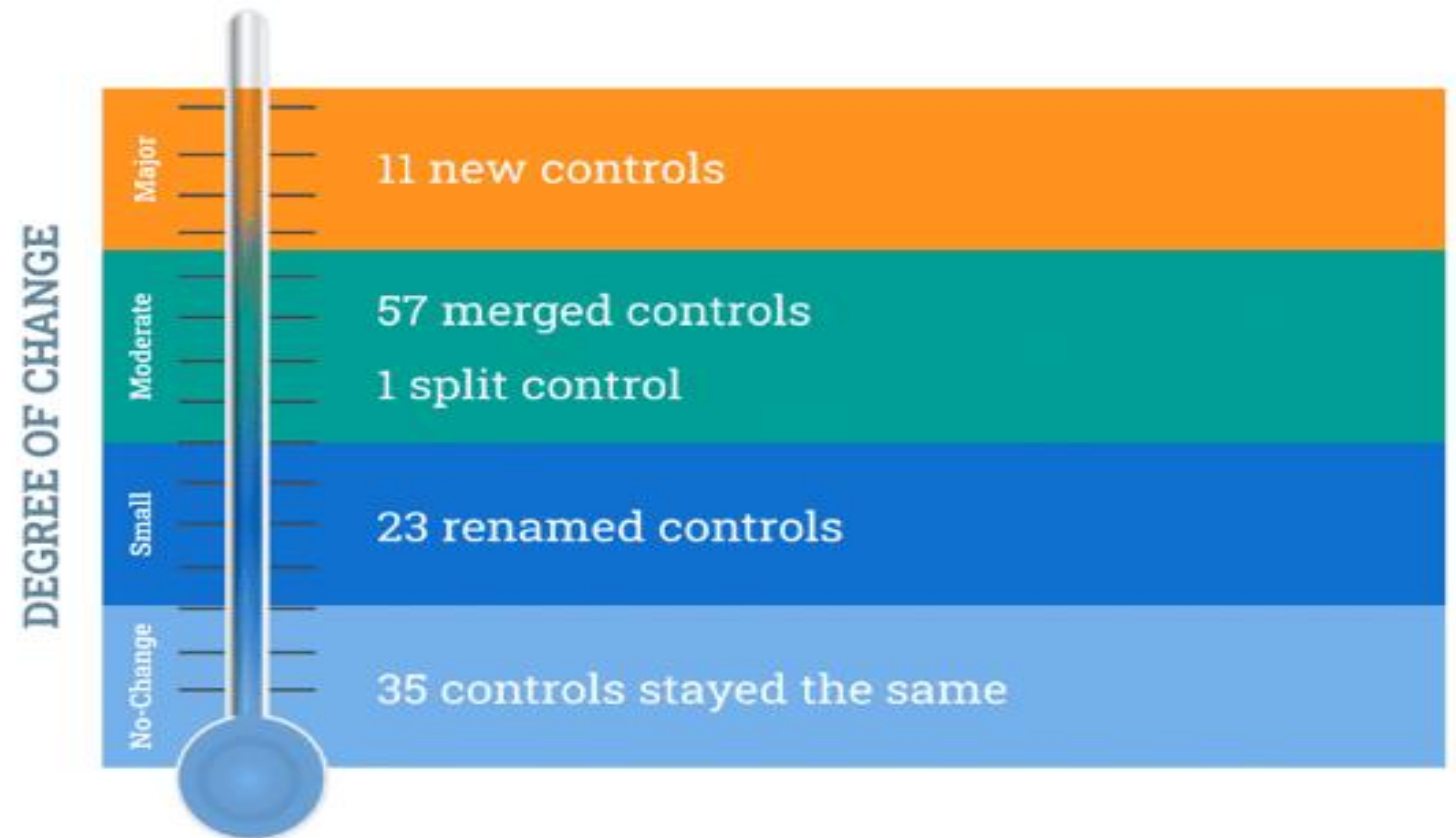
Management review input –changes in needs and expectations of the interested parties

Note: No significant requirements from ISO 27001:2013 were deleted

The controls now also have five types of 'attribute' to make them easier to categories:

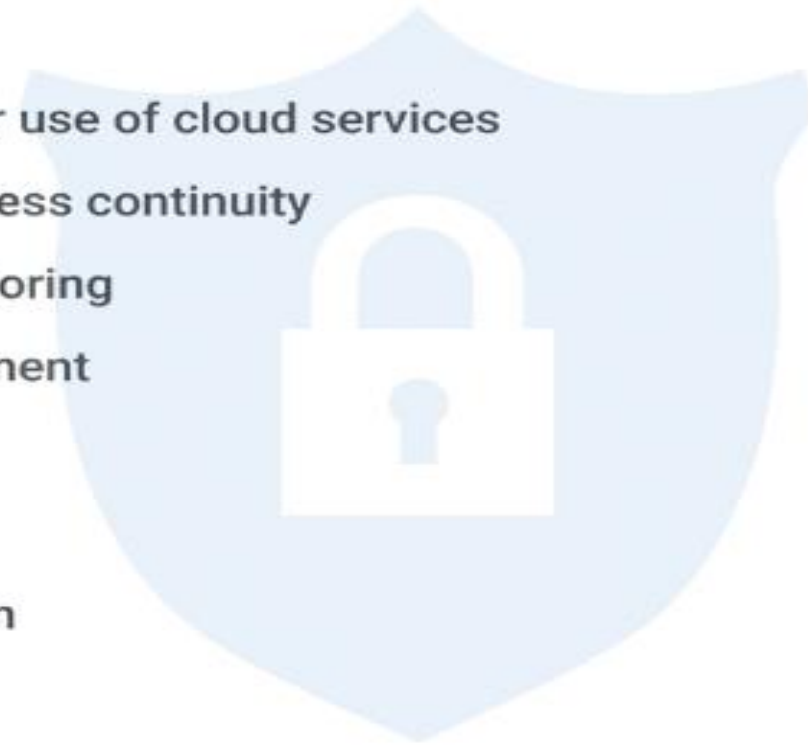
- Control type (preventive, detective, corrective)
- Information security properties (confidentiality, integrity, availability)
- Cyber security concepts (identify, protect, detect, respond, recover)
- Operational capabilities (governance, asset management, etc.)
- Security domains (governance and ecosystem, protection, defense, resilience)

Changes in Annex A security controls



New security controls

- A.5.7** Threat intelligence
- A.5.23** Information security for use of cloud services
- A.5.30** ICT readiness for business continuity
- A.7.4** Physical security monitoring
- A.8.9** Configuration management
- A.8.10** Information deletion
- A.8.11** Data masking
- A.8.12** Data leakage prevention
- A.8.16** Monitoring activities
- A.8.23** Web filtering
- A.8.28** Secure coding



Transition period

